COMPTE RENDU DU TP DE CYBERSECURITE

TP 4.1 — Mise en place d'un pare-feu pfSense et segmentation du laboratoire

1. Objectifs du TP

Ce travail pratique a pour but de transformer un laboratoire réseau totalement ouvert en un réseau contrôlé et segmenté grâce à l'installation et la configuration d'un pare-feu pfSense.

2. Architecture mise en place

Le laboratoire virtuel est composé des machines suivantes :

- Kali Linux : machine attaquante (réseau WAN / NAT)
- Ubuntu :serveur (réseau LAN / Host-Only)
- Windows : poste utilisateur (réseau LAN / Host-Only)
- PfSense : pare-feu placé entre le LAN et le WAN

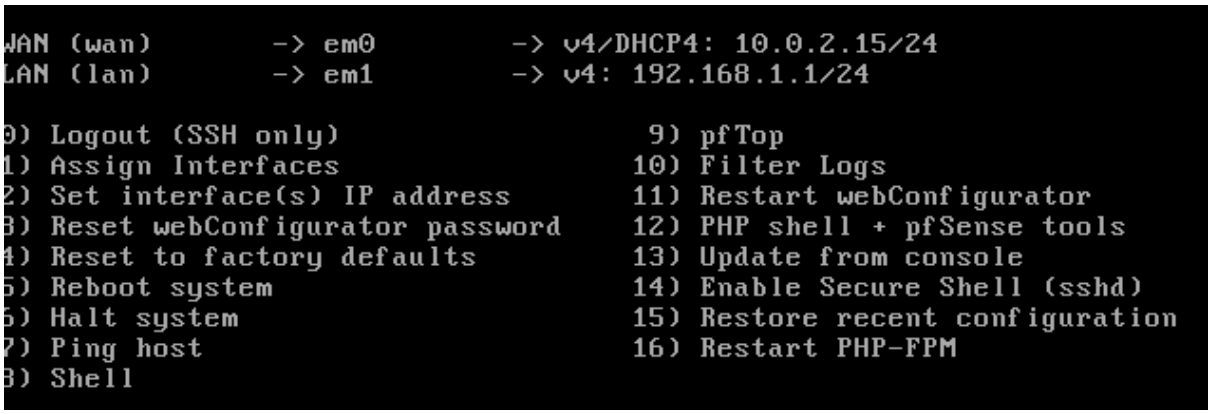
3. Configuration réseau des machines virtuelles

3.1 Machine pfSense

Interface WAN (carte 1) : Mode NAT : accès Internet simulé

Interface LAN (carte 2) : Mode Host-Only : réseau interne isolé

Adresse IP LAN : 192.168.1.1 / 24



3.2 Machine Ubuntu (serveur)

Interface réseau : Host-Only — même réseau que pfSense LAN

Adresse IP : 192.168.1.10 / 24

Passerelle : 192.168.1.1 (pfSense)

Commandes de configuration utilisées :

```
sudo ip addr add 192.168.1.10/24 dev eth0
```

```
sudo ip route add default via 192.168.1.1
```

```
faustin@fautin-faustin:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group defau
lt qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:27:8f:c8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute enp0s3
       valid_lft forever preferred_lft forever
    inet6 fe80::5576:ab5e:dece:2555/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
faustin@fautin-faustin:~$
```

3.3 Machine Windows (poste utilisateur)

Interface réseau : Host-Only

Adresse IP : 192.168.1.20

Masque de sous-réseau : 255.255.255.0

Passerelle : 192.168.1.1

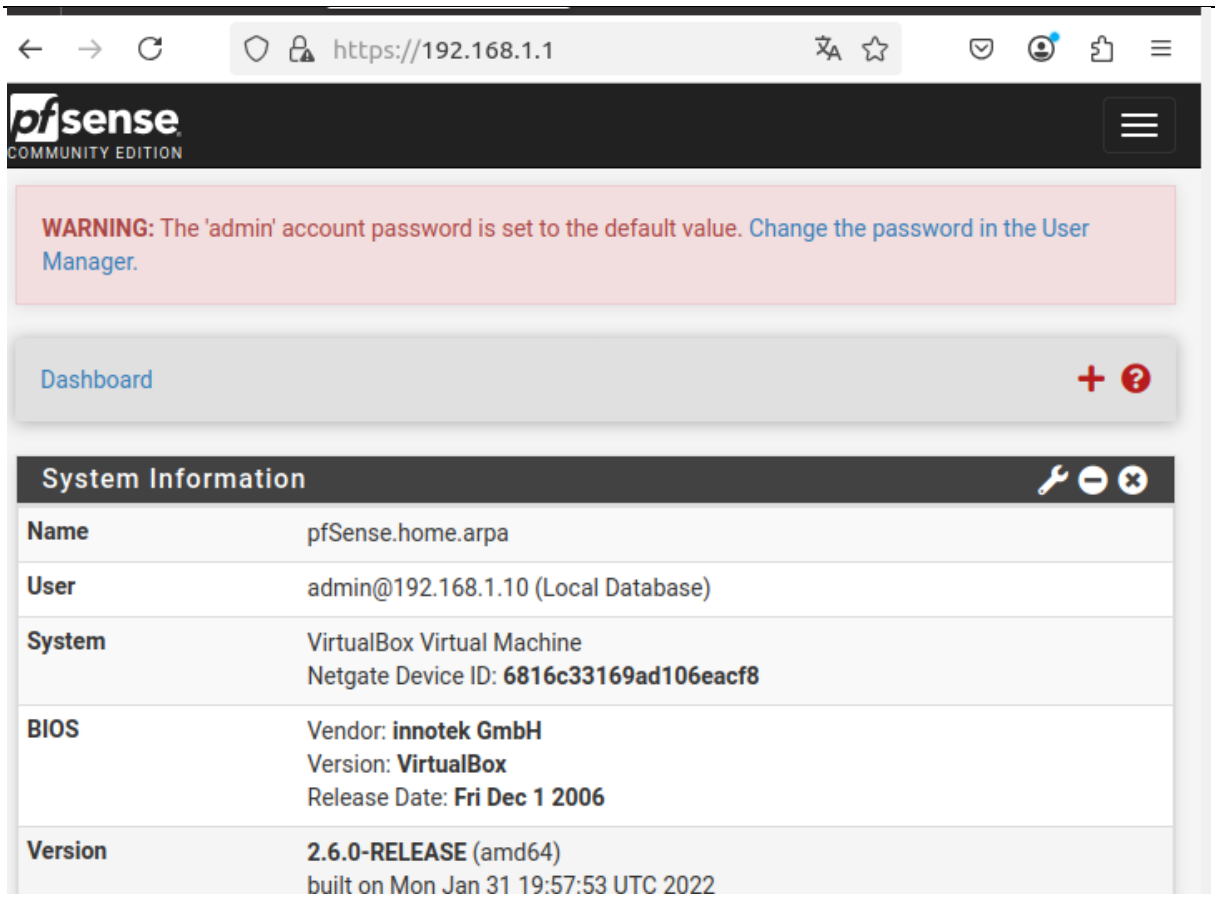
4. Accès et navigation dans l'interface web pfSense

L'interface web d'administration de pfSense est accessible depuis Ubuntu ou Windows à l'adresse suivante :

`https://192.168.1.1`

Identifiant : admin

Mot de passe : pfsense



5. Vérification du routage (Étape 8)

Depuis Ubuntu, test d'accès à Internet via pfSense :

```
ping 8.8.8.8
```

```
faustin@fautin-faustin:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 octets de 8.8.8.8 : icmp_seq=1 ttl=111 temps=106 ms
64 octets de 8.8.8.8 : icmp_seq=2 ttl=111 temps=132 ms
64 octets de 8.8.8.8 : icmp_seq=3 ttl=111 temps=98.8 ms
^C
--- statistiques ping 8.8.8.8 ---
3 paquets transmis, 3 reçus, 0 % paquets perdus, temps 2004 ms
rtt min/moy/max/mdev = 98,793/112,068/131,752/14,198 ms
faustin@fautin-faustin:~$
```

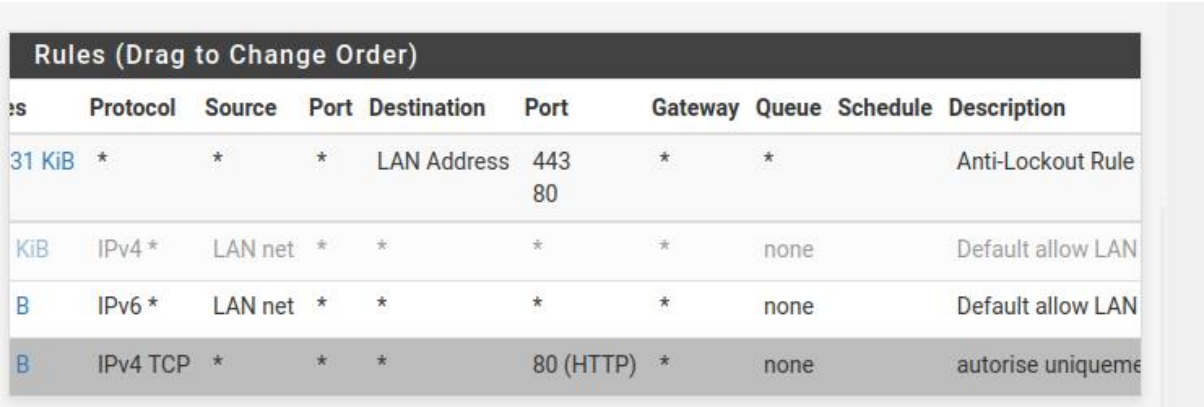
Interprétation : Le ping réussit, ce qui confirme que pfSense route correctement le trafic et que l'architecture WAN/LAN est opérationnelle.

6. Mise en place de la règle de filtrage (Étape 9)

6.1 Règle créée

- Étape 1 : Désactivation de la règle par défaut qui autorise tout le trafic
- Étape 2 : Création d'une nouvelle règle avec les paramètres suivants :

Paramètre	Valeur
Action	Pass (Autoriser)
Interface	LAN
Protocole	TCP
Port de destination	80 (HTTP)
Description	Autoriser uniquement HTTP depuis le LAN



Rules (Drag to Change Order)

es	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description
31 KiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule
KiB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN
B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN
B	IPv4 TCP	*	*	*	80 (HTTP)	*	none		autorise uniqueme

6.2 Explication de la règle

La règle créée fonctionne de la manière suivante :

- Elle AUTORISE : le trafic TCP à destination du port 80 (HTTP) depuis le réseau LAN
- Elle BLOQUE : tout autre type de trafic non explicitement autorisé (ICMP, UDP, autres ports TCP...)
- Principe appliqué : deny by default — tout ce qui n'est pas autorisé est refusé

7. Tests de fonctionnement (Étape 10)

7.1 Test HTTP — trafic autorisé

```
curl http://example.com
```

Observation : La requête HTTP aboutit correctement. pfSense laisse passer le trafic sur le port 80.

7.2 Test ICMP — trafic bloqué

```
ping 8.8.8.8
```

```
faustin@fautin-faustin:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
^C
--- statistiques ping 8.8.8.8 ---
19 paquets transmis, 0 reçus, 100 % paquets perdus, temps 18418 ms
```

Observation : Le ping échoue. pfSense bloque le protocole ICMP car il n'est pas autorisé par la règle.

7.3 Simulation d'un comportement attaquant

Depuis Ubuntu (machine compromise), tentative de scan réseau :

```
nmap -sS 8.8.8.8
```

Résultat : Le scan ne fonctionne pas correctement. pfSense bloque les communications non autorisées, empêchant les communications vers un serveur de commande (C2) et les scans réseau externes.

8. Analyse et interprétation des résultats

Le tableau suivant résume les comportements observés lors des tests :

Test effectué	Résultat observé	Comportement attendu	Interprétation
curl HTTP (port 80)	Succès	Autorisé	Règle Pass TCP 80 active
ping 8.8.8.8 (ICMP)	Échec	Bloqué	ICMP non autorisé
nmap -sS (scan SYN)	Échec	Bloqué	Ports non autorisés

9. Propositions d'améliorations

À la suite de ce TP, plusieurs améliorations peuvent être envisagées pour renforcer la sécurité de l'architecture :

9.1 Autoriser HTTPS uniquement (port 443)

Plutôt qu'autoriser HTTP (port 80, non chiffré), il est préférable de créer une règle Pass TCP sur le port 443 (HTTPS) afin de garantir la confidentialité des échanges. Le port 80 devrait être bloqué ou redirigé vers HTTPS.

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	D
0 /271 KiB	*	*	*	LAN Address	443 80	*	*		
0 /0 B	IPv4 *	LAN net	*	*	*	*	none		
0 /0 B	IPv6 *	LAN net	*	*	*	*	none		
0 /0 B	IPv4 TCP	*	*	*	443 (HTTPS)	*	none		

9.2 Bloquer des ports spécifiques à risque

Des ports couramment exploités par les attaquants devraient être explicitement bloqués : port 23 (Telnet), port 21 (FTP non sécurisé), ports 135-139 (NetBIOS), port 445 (SMB). L'approche recommandée est le principe du moindre privilège : tout bloquer par défaut et n'ouvrir que les ports strictement nécessaires.

0 /0 B	IPv4 TCP	*	*	*	443 (HTTPS)	*	none	
0 /0 B	IPv4 TCP	*	*	*	21 (FTP)	*	none	
0 /0 B	IPv4 TCP	*	*	*	23 (Telnet)	*	none	

Add Add Delete Save Separator

9.3 Ajouter une zone DMZ

Une zone démilitarisée (DMZ) peut être créée comme troisième interface réseau sur pfSense. Les serveurs accessibles depuis Internet (serveur web, serveur mail) y seraient placés, isolés du LAN interne. Cela limite la propagation d'une attaque : si un serveur en DMZ est compromis, l'attaquant ne peut pas atteindre directement le réseau interne.

10. Conclusion

Ce travail pratique a permis de mettre en évidence plusieurs principes fondamentaux de la cybersécurité réseau :

- La sécurité commence par le réseau : un réseau non segmenté est une cible facile

- Un pare-feu bien configuré limite fortement les possibilités d'attaque
- Contrôler les flux est aussi important que sécuriser les machines elles-mêmes
- Même si une machine est compromise, le pare-feu peut empêcher l'exfiltration de données et les communications avec un C2

pfSense s'est révélé être un outil puissant et accessible pour mettre en pratique ces concepts dans un environnement virtualisé reproduisant fidèlement une architecture d'entreprise réelle.